

CR-006: Student Self-Service Enrollment Cancellation

1. Change Request Details

Change Request ID: CR-006

Title: Student Self-Service Enrollment Cancellation

Priority: High

Difficulty: Intermediate

Change Type: Backend authorization and frontend change

2. Business Requirement

Students should be able to cancel their own enrollments without contacting an administrator.

3. Current Behaviour

- Only administrators can delete enrollments.
- Students cannot cancel their own enrollment.

4. Requested Change

Allow students to cancel their own enrollments while protecting other students' records.

The application must:

- Add a student-only endpoint such as: DELETE /api/enrollments/my/:id
- Require authentication.
- Require the Student role.
- Identify the student using req.user.id.
- Not trust a student ID supplied by the client.
- Ensure the delete query checks both the Enrollment ID and the logged-in Student ID.
- Return HTTP 200 after successful cancellation.
- Return HTTP 404 when the enrollment does not exist.
- Return HTTP 404 when the enrollment belongs to another student.
- Return HTTP 400 for an invalid enrollment ID.
- Add a Cancel Enrollment button to My Enrollments.
- Ask for confirmation before cancellation.
- Disable the button while cancellation is in progress.
- Refresh the enrollment list after successful cancellation.
- Show a success message.
- Ensure Course Details shows the correct enrolled or cancelled state.

- Keep the existing admin delete endpoint working.
- Prevent a student from cancelling another student's enrollment.
- Allow the student to enroll in the course again after cancellation.

5. Scope

This change applies to student enrollment cancellation, backend authorization, enrollment deletion, My Enrollments, Course Details, and related frontend feedback.

The change includes:

- Adding a student-only enrollment cancellation endpoint.
- Requiring authentication for student cancellation.
- Requiring the Student role.
- Identifying the logged-in student using req.user.id.
- Preventing client-supplied student IDs from being trusted.
- Checking both enrollment ID and logged-in student ID during deletion.
- Handling invalid enrollment IDs.
- Handling non-existent enrollments.
- Preventing cancellation of another student's enrollment.
- Adding a Cancel Enrollment button.
- Adding cancellation confirmation.
- Disabling the cancellation button during the request.
- Refreshing the enrollment list after successful cancellation.
- Showing a success message.
- Updating Course Details to show the correct enrollment state.
- Maintaining the existing administrator delete functionality.
- Allowing re-enrollment after cancellation.
- Preventing a full page reload during cancellation.

The change does not include:

- Compulsory database schema changes.
- Removal or modification of the existing admin delete endpoint.
- Changes to administrator enrollment deletion permissions.
- Changes to unrelated enrollment functionality.
- Introducing a separate student ID input for cancellation.
- Allowing students to cancel enrollments belonging to other students.

6. Functional Requirements

6.1 Student Enrollment Cancellation Endpoint

FR-001: Student Cancellation Endpoint

The backend must provide a student-only endpoint such as:

DELETE /api/enrollments/my/:id

FR-002: Authentication Requirement

The cancellation endpoint must require the user to be authenticated.

FR-003: Student Role Requirement

The cancellation endpoint must require the Student role.

FR-004: Logged-In Student Identification

The backend must identify the student using:

FR-005: No Client-Supplied Student ID

The cancellation request must not trust a student ID supplied by the client.

FR-006: Enrollment Ownership Validation

The delete operation must verify both:

- The Enrollment ID.
- The ID of the logged-in student.

FR-007: Successful Cancellation

When the logged-in student owns the enrollment and the cancellation is successful, the backend must return HTTP 200.

6.2 Enrollment Error Handling

FR-008: Non-Existent Enrollment

When the specified enrollment does not exist, the backend must return HTTP 404.

FR-009: Another Student's Enrollment

When the specified enrollment belongs to another student, the backend must return HTTP 404.

The endpoint must not reveal or expose another student's enrollment through a successful cancellation response.

FR-010: Invalid Enrollment ID

When the enrollment ID is invalid, the backend must return HTTP 400.

6.3 My Enrollments UI

FR-011: Cancel Enrollment Button

The My Enrollments page must display a Cancel Enrollment button for enrollments that can be cancelled by the logged-in student.

FR-012: Cancellation Confirmation

The application must ask the student for confirmation before cancelling an enrollment.

FR-013: Disable During Cancellation

The Cancel Enrollment button must be disabled while the cancellation request is in progress.

FR-014: Enrollment List Refresh

After successful cancellation, the My Enrollments list must be refreshed.

FR-015: Success Message

After successful cancellation, the application must display a success message.

FR-016: No Full Page Reload

The cancellation action must not cause a full page reload.

6.4 Course Details State

FR-017: Correct Enrollment State

Course Details must show the correct enrolled or cancelled state after the enrollment is cancelled.

FR-018: Cancelled Course State

After successful cancellation, the course must no longer appear as actively enrolled for the student.

FR-019: Re-Enrollment

After cancellation, the student must be able to enroll in the same course again.

6.5 Existing Admin Functionality

FR-020: Existing Admin Delete Endpoint

The existing admin delete enrollment endpoint must continue to work.

FR-021: Admin Functionality Preservation

Existing administrator enrollment deletion behaviour must remain unchanged.

FR-022: Student Authorization Isolation

A student using the student cancellation endpoint must not gain administrator-level deletion capabilities.

6.6 Enrollment Ownership Security

FR-023: Own Enrollment Only

A student may cancel only an enrollment belonging to the logged-in student.

FR-024: Other Student Protection

A student must not be able to cancel another student's enrollment.

FR-025: Server-Side Ownership Check

Enrollment ownership must be enforced on the backend rather than relying only on frontend restrictions.

FR-026: Request Identity Source

The logged-in student's identity must come from the authenticated request context, specifically req.user.id.

7. Security Requirements

SEC-001: Authentication

The student cancellation endpoint must require authentication.

SEC-002: Student Authorization

Only users with the Student role may use the student cancellation endpoint.

SEC-003: Server-Side Identity

The backend must use req.user.id to identify the logged-in student.

SEC-004: No Client Identity Trust

The backend must not rely on a student ID supplied by the client to determine enrollment ownership.

SEC-005: Enrollment Ownership

The deletion query must verify that the enrollment belongs to the logged-in student.

SEC-006: Other Student Data Isolation

A student must not be able to cancel or modify an enrollment belonging to another student.

SEC-007: Not Found Protection

When an enrollment belongs to another student, the endpoint must return HTTP 404 rather than allowing cancellation.

SEC-008: Existing Admin Authorization

Existing administrator authorization and enrollment deletion behaviour must remain intact.

SEC-009: No Authorization Bypass

The new endpoint must not provide students with access to administrator-only enrollment deletion functionality.

8. Configuration / Potentially Affected Components

Backend

Potentially affected areas include:

- backend/routes/enrollmentRoutes.js
- backend/controllers/enrollmentController.js
- backend/models/enrollmentModel.js

The backend changes include:

- New student enrollment cancellation endpoint.
- Student-role authorization.
- Logged-in student identification using req.user.id.
- Enrollment ownership validation.
- Invalid enrollment ID handling.
- HTTP 200 successful cancellation response.
- HTTP 404 handling for non-existent or other-student enrollments.
- HTTP 400 handling for invalid enrollment IDs.

Frontend

Potentially affected areas include:

- frontend/src/pages/MyEnrollments.jsx
- frontend/src/pages/CourseDetails.jsx
- frontend/src/App.css

The frontend changes include:

- Cancel Enrollment button.
- Confirmation before cancellation.
- Cancellation loading/disabled state.
- Enrollment list refresh.
- Success message.
- Correct enrolled/cancelled Course Details state.
- Re-enrollment support after cancellation.
- No full page reload.

Database

No compulsory database changes are required.

Existing enrollment data should continue to be used to determine:

- Enrollment ID.
- Student ownership.
- Course association.
- Enrollment state.

Expected Files

The expected files are:

- backend/routes/enrollmentRoutes.js
- backend/controllers/enrollmentController.js
- backend/models/enrollmentModel.js
- frontend/src/pages/MyEnrollments.jsx
- frontend/src/pages/CourseDetails.jsx
- frontend/src/App.css

Students must perform an impact analysis before implementation.

If additional files are modified, they must be identified and justified in the Implementation Report.

9. Constraints / Assumptions

- Students must only be able to cancel their own enrollments.
- Authentication must be required.
- The Student role must be required.
- The backend must use req.user.id to identify the student.
- A student ID supplied by the client must not be trusted.
- The deletion query must check both enrollment ID and logged-in student ID.
- An invalid enrollment ID must return HTTP 400.
- A non-existent enrollment must return HTTP 404.
- An enrollment belonging to another student must return HTTP 404.
- Successful cancellation must return HTTP 200.
- The existing admin delete endpoint must continue to work.
- The Cancel Enrollment button must require confirmation.
- The button must be disabled while cancellation is in progress.
- The enrollment list must refresh after successful cancellation.
- A success message must be displayed after successful cancellation.
- Course Details must show the correct enrolled or cancelled state.
- The student must be able to enroll in the same course again after cancellation.
- The cancellation action must not cause a full page reload.
- No compulsory database changes are required.
- Existing enrollment functionality should continue to work.
- Existing administrator deletion functionality should continue to work.
- Backend authorization must remain the authoritative protection against cross-student cancellation.

10. Acceptance Criteria

AC-001: Student Can Cancel Own Enrollment

An authenticated Student can successfully cancel an enrollment that belongs to them.

AC-002: Authentication Required

An unauthenticated user cannot use the student enrollment cancellation endpoint.

AC-003: Student Role Required

A user without the Student role cannot use the student enrollment cancellation endpoint.

AC-004: Logged-In Student Identification

The backend identifies the student using req.user.id.

AC-005: Client Student ID Not Trusted

The cancellation operation does not rely on a student ID supplied by the client.

AC-006: Enrollment Ownership Check

The delete operation checks both the enrollment ID and the logged-in student ID.

AC-007: Other Student Protection

A student cannot cancel another student's enrollment.

AC-008: Other Student Returns 404

When a student attempts to cancel another student's enrollment, the endpoint returns HTTP 404.

AC-009: Non-Existent Enrollment

When the specified enrollment does not exist, the endpoint returns HTTP 404.

AC-010: Invalid Enrollment ID

When an invalid enrollment ID is supplied, the endpoint returns HTTP 400.

AC-011: Successful Cancellation Response

A successful cancellation returns HTTP 200.

AC-012: Enrollment Disappears

After successful cancellation, the cancelled enrollment disappears from the student's My Enrollments list.

AC-013: Cancel Enrollment Button

My Enrollments displays a Cancel Enrollment button for cancellable enrollments.

AC-014: Cancellation Confirmation

The student is asked to confirm before the enrollment is cancelled.

AC-015: Button Disabled During Cancellation

The Cancel Enrollment button is disabled while the cancellation request is in progress.

AC-016: Enrollment List Refresh

After successful cancellation, the enrollment list is refreshed without requiring a full page reload.

AC-017: Success Message

After successful cancellation, the student sees a success message.

AC-018: Course Details State

Course Details shows the correct enrolled or cancelled state after cancellation.

AC-019: Re-Enrollment

After cancelling an enrollment, the student can enroll in the same course again.

AC-020: Admin Delete Still Works

The existing administrator delete enrollment endpoint continues to work correctly.

AC-021: Student Cannot Gain Admin Delete Access

The new student endpoint does not provide students with administrator-level enrollment deletion capabilities.

AC-022: No Cross-Student Modification

A student cannot modify or delete another student's enrollment through the cancellation functionality.

AC-023: Backend Authorization

Ownership and authorization are enforced by the backend and are not dependent solely on frontend restrictions.

AC-024: No Full Page Reload

Cancelling an enrollment does not cause a full browser page reload.

AC-025: Existing Enrollment Functionality

Existing enrollment functionality continues to work correctly after the change.

AC-026: Existing Admin Functionality

Existing administrator enrollment management continues to work correctly after the change.

AC-027: No Database Changes Required

The functionality can be implemented without compulsory database schema changes.

AC-028: Enrollment Reuse

After cancellation, the student can create a new enrollment for the same course.

11. Expected Outcome

After implementation:

- Students can cancel their own enrollments without contacting an administrator.
- The cancellation endpoint requires authentication.
- The cancellation endpoint requires the Student role.
- The backend identifies the student using req.user.id.
- The backend does not trust a student ID supplied by the client.
- Enrollment deletion verifies both the enrollment ID and logged-in student ID.
- Students cannot cancel another student's enrollment.
- Non-existent enrollments return HTTP 404.
- Enrollments belonging to another student return HTTP 404.
- Invalid enrollment IDs return HTTP 400.
- Successful cancellation returns HTTP 200.
- The cancelled enrollment disappears from My Enrollments.
- The Cancel Enrollment button requires confirmation.
- The Cancel Enrollment button is disabled while cancellation is in progress.
- The enrollment list refreshes after successful cancellation.
- A success message is displayed after cancellation.
- Course Details shows the correct enrolled or cancelled state.
- The student can enroll in the same course again after cancellation.
- The cancellation action does not cause a full page reload.
- The existing admin delete endpoint continues to work.
- Existing enrollment functionality continues to work correctly.
- No compulsory database changes are required.